

SIMATS ENGINEERING ASSESSMENT TOOL II – INDUSTRY PROBLEM TASK

Course: Ethical Hacking	Code: ITA1416	CO: CO5
Duration:	Total Marks: 100	Reg No / Name: SHAM S. (192325076)

COURSE OUTCOME COVERED

CO5: *Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Instructions: *Answer all questions. Each question carries 20 marks.*

1. A mid-sized financial organization operates a Windows domain network consisting of 150 interconnected systems. During a security incident investigation, it is observed that attackers have exploited NULL sessions, open RPC services, and misconfigured shared folders to gain unauthorized access. Initial analysis indicates that 45% of systems allow anonymous enumeration, and among those, 60% are susceptible to SMB-based lateral movement attacks. Furthermore, each compromised system can attempt to access 3 additional systems, with a success probability of 0.3 per attempt. **Question:**

Analyze the extent of the attack by calculating the number of systems compromised during the initial stage of exploitation. Further, estimate the spread of the attack in the second stage due to lateral movement. Based on your analysis, evaluate whether the network is at risk of a

large-scale compromise (greater than 70% of total systems), and justify which vulnerability (NULL sessions, RPC exposure, or weak shares) should be prioritized for immediate mitigation.

2. An enterprise network consists of 120 systems, out of which 70 systems expose RPC services to the internal network. A vulnerability scan reveals that 40% of these systems are susceptible to known exploits, and the probability of successful exploitation for each vulnerable system is 0.5. However, each exploitation attempt carries a detection probability of 0.25 due to intrusion detection systems deployed within the network.

Question:

Determine the expected number of systems that can be successfully compromised by an attacker. Additionally, compute the expected number of detection alerts generated during the exploitation process. Based on your results, critically evaluate whether an attacker aiming to remain stealthy would proceed with exploitation or adopt alternative attack strategies, providing justification for your reasoning.

3. A cloud-hosted Linux server is running multiple services exposed to the internet. Security analysis identifies four critical services, with independent probabilities of vulnerability being 0.3, 0.2, 0.25, and 0.15, respectively. It is also observed that the system has weak file permissions, which can be exploited with a probability of 0.5 once initial access is gained.

Question:

Evaluate the probability that at least one service is vulnerable and can be exploited by an attacker. Further, compute the overall probability of a full system compromise, considering both

service exploitation and privilege escalation through weak permissions. Based on your findings, analyze whether strengthening file permissions alone would significantly reduce the overall risk, and justify your conclusion.

4. An organization uses Network File System (NFS) to share resources across three internal subnets. Due to improper configuration, unauthorized access probabilities from these subnets are estimated as 0.4, 0.3, and 0.2, respectively. Once access to the NFS share is obtained, the probability of privilege escalation to root access is 0.7. **Question:**

Calculate the probability that at least one subnet successfully gains unauthorized access to the NFS share. Subsequently, determine the overall probability of a complete system compromise. Based on your analysis, evaluate the effectiveness of restricting NFS access to a single subnet as a mitigation strategy, and justify your recommendation.

5. An e-commerce platform maintains a database containing 50,000 user records, of which 30% are classified as sensitive. A successful SQL injection attack allows data extraction at a rate of 500 records per second. However, the application firewall detects and blocks the attack after 40 seconds. **Question:**

Compute the total number of records that can be extracted before the attack is blocked. Determine the percentage of total data compromised, and estimate the number of sensitive records exposed. Based on your analysis, evaluate the severity of the breach and justify whether the existing detection mechanism is sufficient to protect critical data.

Code of Conduct:

I M.Chaitanya Naidu (192472047) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning	Mark
Understanding of Industry Problem	20%	Comprehensive understanding of realworld problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding; misinterpret s problem context	
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts	

Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution	
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools	
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis	
Professionalism	5%	Highly professional, well documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation	

1. Windows Domain Network – NULL Sessions, RPC and Weak Shares

Given:

- Total systems = **150**
- Systems allowing anonymous enumeration = **45%**
- Of these, SMB-lateral-movement susceptible = **60%**
- Each compromised system attempts = **3 systems**
- Success probability per attempt = **0.3**

Step 1: Initial systems affected by anonymous enumeration $150 \times 45\% = 150 \times 0.45 = 67.5$

$150 \times 45\% = 150 \times 0.45 = 67.5$

Approximately:

68 systems \boxed{68 \text{ systems}}

Step 2: Systems susceptible to SMB lateral movement

$68 \times 60\% = 40.8$ \times 60\% = 40.8 Approximately:

41 systems \boxed{41 \text{ systems}}

So, the **initial stage** can compromise approximately **41 systems**.

Step 3: Second-stage lateral movement

Each compromised system attempts to access 3 additional systems.

Total attempts:

$$41 \times 3 = 123$$

Probability of successful access = 0.3.

Expected successful compromises:

$$123 \times 0.3 = 36.9$$

Therefore:

Second-stage spread ≈ 37 systems

Step 4: Total estimated compromised systems

$$41 + 37 = 78$$

Therefore:

78 systems

Percentage of network:

$$\frac{78}{150} \times 100 = 52\%$$

Analysis

The estimated compromise is **52%**, which is below the **70% large-scale compromise threshold**.

70% of 150 systems:

$$150 \times 0.70 = 105$$

Since:

$$78 < 105$$

the network is **not expected to cross the 70% threshold in these two stages**.

Priority of mitigation

NULL sessions should be prioritized first, because they enable anonymous enumeration of a large portion of the network. Reducing anonymous access makes it harder for attackers to discover systems, users and shares that can later be used for SMB-based lateral movement.

Recommended controls:

- Disable unnecessary NULL/anonymous sessions.
- Restrict SMB access.
- Secure shared-folder permissions.
- Disable unnecessary RPC services.
- Apply network segmentation.

Final Answer:

Initial compromise ≈ 41 Second-stage

spread ≈ 37

Total $\approx 78/150 = 52\%$

Conclusion: The network has a significant lateral-movement risk, but the estimated spread does not exceed 70%. **NULL sessions should receive immediate attention**, followed by SMB/weakshare and RPC hardening.

2. RPC Exposure and Exploitation

Given:

- Total systems = **120**
- Systems exposing RPC = **70**
- Vulnerable RPC systems = **40%**
- Exploitation success probability = **0.5**
- Detection probability per attempt = **0.25**

Step 1: Number of vulnerable systems

$$70 \times 0.40 = 28$$

Therefore:

28 vulnerable systems

Step 2: Expected successful compromises

Probability of successful exploitation = 0.5.

$$28 \times 0.5 = 14$$

Therefore:

14 systems

Step 3: Expected detection alerts

Detection probability = 0.25.

Assuming one exploitation attempt against each vulnerable system:

$$28 \times 0.25 = 7$$

Therefore:

7 detection alerts

Step 4: Interpretation

The attacker has an expected:

- 14 successful compromises ● 7 detection alerts

This means the exploitation has a reasonable success rate, but it also creates a substantial chance of detection.

Probability of success:

$$50\%$$

Probability of detection:

$$25\%$$

For a stealth-focused attacker, repeatedly exploiting all vulnerable RPC systems may be risky because approximately **one out of every four attempts may generate an alert**.

Recommendation

A stealth-oriented attacker would likely avoid noisy, repeated exploitation and may seek **low noise attack paths**, such as exploiting other exposed weaknesses or using already obtained legitimate access.

From the defender's perspective:

- Restrict RPC exposure.
- Patch vulnerable systems.
- Monitor unusual RPC activity.
- Improve IDS/IPS rules.
- Segment internal networks.

Final Answer:

28 vulnerable systems 14 expected

compromises\boxed{14}\text{ expected compromises}} 7 expected alerts\boxed{7}\text{ expected alerts}}

Conclusion: RPC exploitation presents a meaningful risk, but the 25% detection probability makes repeated exploitation less attractive for an attacker attempting to remain stealthy.

3. Cloud Linux Server – Service Vulnerabilities and Weak Permissions

Given:

Four independent services have vulnerability probabilities: $P_1=0.3$ $P_1=0.3$

$P_2=0.2$ $P_2=0.2$ $P_3=0.25$ $P_3=0.25$ $P_4=0.15$ $P_4=0.15$

Weak file permissions can be exploited with probability:

$P_P=0.5$ $P_P=0.5$

Step 1: Probability that no service is vulnerable

For each service, probability of **not being vulnerable** is:

$1-0.3=0.7$ $1-0.3=0.7$ $1-0.2=0.8$ $1-0.2=0.8$ $1-0.25=0.75$ $1-0.25=0.75$ $1-0.15=0.85$ $1-0.15=0.85$

Because the services are independent:

$P(\text{none vulnerable})=0.7 \times 0.8 \times 0.75 \times 0.85$ $P(\text{none vulnerable})$
 $=0.7 \times 0.8 \times 0.75 \times 0.85 = 0.357 = 0.357$

Step 2: Probability that at least one service is vulnerable

$P(\text{at least one})=1-P(\text{none})$ $P(\text{at least one})=1-P(\text{none})=1-0.357=1-0.357$
 $=0.643=\boxed{0.643}$

Therefore:

64.3% $\boxed{64.3\%}$

There is a **64.3% probability** that at least one exposed service is vulnerable.

Step 3: Probability of full system compromise

After obtaining initial access, weak permissions can be exploited with probability 0.5.

Therefore:

$P(\text{full compromise})=P(\text{initial access}) \times P(\text{privilege escalation})$ $P(\text{full compromise})=$

$$P(\text{initial access}) \times P(\text{privilege escalation}) = 0.643 \times 0.5 = 0.643 \times 0.5 = 0.3215 = 0.3215$$

Therefore:

$$32.15\% \boxed{32.15\%}$$

Analysis

The initial service vulnerability risk is **64.3%**, which is relatively high.

Even though privilege escalation succeeds only 50% of the time, the overall probability of full compromise remains approximately:

$$32.15\% \boxed{32.15\%}$$

Strengthening file permissions alone would reduce the **privilege-escalation portion** of the attack, but it would **not eliminate the initial-access risk** from vulnerable internet-facing services.

Recommendation

The organization should use a **defense-in-depth approach**:

1. Patch vulnerable services.
2. Reduce unnecessary internet exposure.
3. Use firewalls/security groups.
4. Strengthen file permissions.
5. Apply least privilege.
6. Monitor suspicious service activity.

Final Answer:

$$P(\text{at least one vulnerable service}) = 64.3\% \boxed{P(\text{at least one vulnerable service}) = 64.3\%} \quad P(\text{full compromise}) = 32.15\% \boxed{P(\text{full compromise}) = 32.15\%}$$

Conclusion: Strengthening file permissions is useful, but **not sufficient by itself**. Internet-facing service vulnerabilities must also be addressed because they provide the initial entry point.

4. NFS Unauthorized Access

Given:

Three subnets have unauthorized-access probabilities:

$$P_1 = 0.4 \quad P_2 = 0.3 \quad P_3 = 0.2$$

Probability of privilege escalation to root:

$$P_R = 0.7$$

Step 1: Probability that no subnet gains access

Probability of no unauthorized access:

Subnet 1:

$$1 - 0.4 = 0.6$$

Subnet 2:

$$1 - 0.3 = 0.7$$

Subnet 3:

$$1 - 0.2 = 0.8$$

Therefore:

$$P(\text{no access}) = 0.6 \times 0.7 \times 0.8 = 0.336$$

Step 2: Probability of at least one unauthorized access

$$P(\text{at least one access}) = 1 - 0.336 = 0.664$$

Therefore:

$$66.4\%$$

Step 3: Probability of complete system compromise

Privilege escalation probability = 0.7.

$$P(\text{complete compromise}) = 0.664 \times 0.7 = 0.4648$$

Therefore:

$$46.48\%$$

Step 4: Effect of restricting NFS to one subnet

Suppose access is restricted to the **first subnet**, whose unauthorized-access probability is 0.4.

Then:

$$P(\text{access}) = 0.4$$

Complete compromise:

$$0.4 \times 0.7 = 0.28 \quad 0.4 \times 0.7 = 0.28 \quad 28\% \boxed{28\%}$$

Comparison:

Configuration	Complete compromise probability
Three subnets	46.48%
Only subnet 1	28%

Risk reduction:

$$46.48 - 28 = 18.48 \text{ percentage points} \quad 46.48 - 28 = 18.48 \text{ percentage points}$$

Analysis

Restricting NFS access to one trusted subnet reduces the probability of unauthorized access from **66.4% to 40%** and reduces the estimated complete compromise probability from **46.48% to 28%**.

Therefore, restricting NFS access is an **effective mitigation strategy**.

Additional controls:

- Use NFS export restrictions.
- Apply strong host-based access controls.
- Use least privilege.
- Monitor NFS access.
- Prevent unnecessary root privileges.

Final Answer:

$$P(\text{unauthorized access}) = 66.4\% \boxed{P(\text{unauthorized access}) = 66.4\%} \quad P(\text{complete compromise}) = 46.48\% \boxed{P(\text{complete compromise}) = 46.48\%}$$

After restricting access to subnet 1:

$$P(\text{complete compromise}) = 28\% \boxed{P(\text{complete compromise}) = 28\%}$$

Conclusion: Restricting NFS access to a single trusted subnet significantly reduces the attack surface and should be implemented.

5. SQL Injection and Data Exposure

Given:

- Total records = **50,000**
- Sensitive records = **30%**
- Extraction rate = **500 records/second**
- Detection/blocking time = **40 seconds**

Step 1: Total records extracted

$$500 \times 40 = 20,000 \text{ records}$$

Therefore, before the firewall blocks the attack, approximately **20,000 records** can be extracted.

Step 2: Percentage of total data compromised

$$\frac{20,000}{50,000} \times 100 = 40\%$$

Therefore:

40% of the database

could be compromised.

Step 3: Number of sensitive records

Sensitive records:

$$50,000 \times 30\% = 15,000$$

Assuming the extracted records have the same sensitive-data proportion:
 $20,000 \times 30\% = 6,000$

Therefore:

6,000 sensitive records could

potentially be exposed.

Step 4: Severity analysis

The breach is **high severity** because:

- 20,000 out of 50,000 records can be extracted.
- This represents **40% of the entire database**.
- Approximately **6,000 sensitive records** may be exposed.
- SQL injection can potentially provide large-scale unauthorized data access.

Is the firewall sufficient?

No, the existing detection mechanism is not sufficient by itself.

The firewall takes **40 seconds** to block the attack, but during those 40 seconds:

20,000 records\boxed{20,000\text{ records}}

can potentially be extracted.

A stronger security design should include:

- Parameterized SQL queries/prepared statements.
- Input validation.
- Secure database permissions.
- Web Application Firewall (WAF).
- Rate limiting.
- Database activity monitoring.
- Immediate alerting and blocking.
- Regular vulnerability testing.

Final Answer:

Records extracted=20,000\boxed{\text{Records extracted}=20,000} Percentage compromised=40%\boxed{\text{Percentage compromised}=40\%} Sensitive records exposed≈6,000\boxed{\text{Sensitive records exposed}\approx6,000}

Conclusion: The breach should be considered **high severity**. A 40-second detection window is too long because a large amount of information can be extracted before blocking. Preventing SQL injection at the application/database level is more effective than relying only on detection.

Overall Summary

Q	Main Result	Security Evaluation
1	Initial ≈ 41 , second stage ≈ 37 , total ≈ 78 systems	52%, below 70% threshold; prioritize NULL sessions
2	14 compromises, 7 alerts	Exploitation has meaningful detection risk for stealthy attackers
3	Vulnerable service probability = 64.3% ; full compromise = 32.15%	File permissions alone are not sufficient
4	Unauthorized NFS access = 66.4% ; full compromise = 46.48%	Restricting NFS to one subnet reduces risk to 28%
5	20,000 records, 40%, ≈ 6,000 sensitive records	High-severity breach ; firewall alone is insufficient

Overall Security Recommendation

The organization should follow **defense in depth** rather than relying on a single control. The most important measures are **patch management, least privilege, secure configurations, network segmentation, restricting unnecessary services, strong access controls, continuous monitoring, and secure application development practices.**